

Platform Security Controls Specification

Document Reference: SEC-CTL-005

1 The system shall implement identity and access management controls in accordance with ISO/IEC 27001:2022 Annex A controls 5.15 through 5.18.

1.1 The system shall enforce a formal user provisioning process that includes approval, documentation, and periodic review.

- New accounts shall require line manager and information security approval before activation.
- Account provisioning requests shall be logged with the requester, approver, timestamp, and business justification.
- Accounts shall be provisioned with the minimum permissions required for the stated business purpose.

1.1.1 The provisioning workflow shall enforce the following sequence without exception:

- Request submitted by requester via the identity management portal.
- Automatic policy check against role catalogue.
- Line manager approval via email workflow.
- Information security review for privileged access requests.
- Account creation and confirmation email to requester.

1.1.2 The system shall not permit self-approval of access requests under any circumstances.

1.2 The system shall implement automated deprovisioning to ensure timely removal of access when no longer required.

- Accounts shall be disabled automatically upon receipt of a leaver notification from HR.
- Disabled accounts shall be fully deleted after 90 days.
- Access tokens and API keys associated with a disabled account shall be revoked immediately.

1.2.1 The deprovisioning process shall complete within the following timeframes after trigger:

- Standard leavers: account disabled within 1 business day of the leaver date.
- Disciplinary terminations: account disabled within 1 hour of HR notification.
- Contractor off-boarding: access removed on or before the contract end date.

1.3 Privileged access (administrative, service, and system accounts) shall be subject to additional controls beyond those applied to standard user accounts.

- Privileged accounts shall be distinct from standard user accounts and shall not be used for day-to-day activities.
- All privileged session activity shall be recorded using the organisation-approved privileged access management tool.
- Privileged credentials shall be rotated at least every 90 days and immediately after any suspected compromise.

1.3.1 Break-glass emergency accounts shall be subject to the following controls:

- Credentials shall be stored in a sealed physical envelope in the information security safe.
- Use of a break-glass account shall automatically trigger an incident in the SIEM.
- Credentials shall be changed immediately after any use of a break-glass account.
- Break-glass account use shall be reviewed by the CISO within 24 hours.

2 The system shall implement network security controls to protect all components from unauthorised network access and data interception.

2.1 All system components shall be deployed within appropriately segmented network zones based on their function and data classification.

- Presentation tier (web servers) — DMZ network zone.
- Application tier (app servers) — Application network zone.
- Data tier (databases, file stores) — Data network zone.
- Management components — Out-of-band management network zone.

2.1.1 Inter-zone traffic shall be controlled by the following rules:

- All inter-zone traffic shall pass through a next-generation firewall with application-layer inspection.
- Default-deny rules shall be applied and only explicitly permitted traffic shall flow between zones.
- Firewall rules shall be reviewed and re-certified every 6 months.

2.2 The system shall implement perimeter protection controls to prevent unauthorised external access.

2.2.1 The following perimeter controls shall be deployed and maintained:

- Web Application Firewall (WAF) in front of all public-facing endpoints.
- DDoS mitigation service with automatic traffic scrubbing for attacks exceeding 1 Gbps.
- Intrusion Prevention System (IPS) inline on all external network paths.
- Rate limiting on all public API endpoints (max 100 requests/minute per source IP by default).

2.3 All data transmitted between system components and between the system and external parties shall be encrypted in transit.

- TLS 1.3 shall be used for all external connections.
- TLS 1.2 with strong cipher suites is permitted for internal service-to-service communication pending migration.
- Unencrypted protocols (HTTP, FTP, Telnet, SNMP v1/v2) shall not be used on any production network path.

3 The system shall implement endpoint and server protection controls on all components deployed in the production environment.

3.1 All servers and endpoints shall run organisation-approved antimalware software with up-to-date definitions.

- Signature updates shall be applied within 4 hours of release.
- Scheduled full-system scans shall run at least weekly outside business hours.
- Real-time scanning shall be enabled at all times and shall not be disabled without change management approval.

3.2 The system shall deploy Endpoint Detection and Response (EDR) tooling on all servers within the production environment.

- – Defender for Endpoint
- – Defender for Servers
- – Defender for Cloud
- – Threat intelligence, automated response and advanced reporting

3.2.1 EDR alerts at Critical or High severity shall be triaged within the following timeframes:

- Critical — acknowledged within 15 minutes, contained within 1 hour.
- High — acknowledged within 1 hour, contained within 4 hours.
- Medium — acknowledged within 4 hours, remediated within 24 hours.

3.3 All system components shall be subject to the organisation's patch management process with the following mandatory timelines.

3.3.1 Operating system and middleware patches shall be applied within the following timeframes:

- Critical (CVSS ≥ 9.0) — emergency patching within 72 hours of vendor release.
- High (CVSS 7.0–8.9) — patching within 14 days of vendor release.
- Medium (CVSS 4.0–6.9) — patching within 30 days.
- Low (CVSS < 4.0) — patching in the next scheduled maintenance window.

4 The system shall implement comprehensive logging and monitoring to support security incident detection, investigation, and regulatory compliance.

4.1 The following events shall be logged by all system components and forwarded to the centralised SIEM within 60 seconds of occurrence.

4.1.1 Authentication events to be logged include:

- ■ Successful and failed login attempts (username, timestamp, source IP, MFA result).
- ■ Account lockouts.
- ■ Password changes and resets.
- ■ MFA bypass or fallback use.

4.1.2 Authorisation events to be logged include:

- ■ Access grants and denials for sensitive data.
- ■ Privilege escalation events.
- ■ Role assignment changes.
- ■ Policy rule changes.

4.2 Security event logs shall be retained in accordance with the following policy.

- Online (queryable) retention: 90 days minimum.
- Archived retention: 12 months minimum.
- Long-term archive (for regulated data): 7 years minimum.

4.3 The SIEM shall be configured with detection rules covering at minimum the following threat scenarios.

- Brute-force and credential stuffing attacks.
- Anomalous login times or geographic locations.
- Lateral movement indicators.
- Data exfiltration patterns (large outbound transfers).
- Ransomware indicators (high-volume file modifications).

5 The system shall support the organisation's incident response capability through automated detection, alerting, and containment functions.

5.1 The system shall implement automated response actions for specific high-confidence threat scenarios without requiring manual authorisation.

- Automatically isolate a compromised endpoint from the network when EDR confidence exceeds 90%.
- Automatically revoke active sessions for an account when credential compromise is confirmed.
- Automatically block a source IP exhibiting brute-force behaviour after 10 failed attempts in 60 seconds.

5.2 Security incidents shall be classified using the following severity levels, each with defined response timelines.

- P1 Critical: system breach with data exfiltration confirmed or suspected.
- P2 High: active attack in progress but contained within a single system.

- P3 Medium: suspicious activity requiring investigation.
- P4 Low: policy violation or anomaly without evidence of attack.

5.2.1 Incident response timelines by severity:

- P1 Critical — CISO notification within 30 minutes; regulatory authority notification within 72 hours.
- P2 High — Incident Response Team assembled within 1 hour.
- P3 Medium — investigation commenced within 4 hours.
- P4 Low — reviewed in the next scheduled security operations meeting.